Security Risk Assessment Report

This is a Security Risk Assessment Report for a <u>fictional</u> scenario given as an activity for the *Connect and Protect: Networks and Network Security Course* in Coursera

Scenario:
You are a security analyst working for a social media organization. The organization recently experienced a major data breach, which compromised the safety of their customers' personal information, such as names and addresses. Your organization wants to implement strong network hardening practices that can be performed consistently to prevent attacks and breaches in the future.

After inspecting the organization's network, you discover four major vulnerabilities. The four vulnerabilities are as follows:

1. The organization's employees' share passwords.
2. The admin password for the database is set to the default.
3. The firewalls do not have rules in place to filter traffic coming in and out of the network.
4. Multifactor authentication (MFA) is not used.

If no action is taken to address these vulnerabilities, the organization is at risk of experiencing another data breach or other attacks in the future. In this activity, you will write a security risk assessment to analyze the incident and explain what methods can be used to further secure the network.

Part 1: Select up to three hardening tools and methods to implement
Password Policies Multifactor Authentication (MFA) Firewall Maintenance, Disabling Unused Ports, Port Filtering Additional tools: Encryption using the Latest Standards Server and Data Storage Backups Usage of SIEM tools and IPS Patch updates

Part 2: Explain your recommendations

Password Policies:
A password policy makes every employee use strong passwords and bans password sharing. It also requires changing the default database admin password. This should be set once and enforced all the time. Review the policy about once a year, and after any incident. This addresses vulnerability 1 and 2.

Multifactor Authentication (MFA):
MFA asks for a second proof of identity on top of the password. A stolen or shared password alone can no longer open an account. This needs to be enforced at every login. Review who has access every few months and whenever an employee joins or leaves. This addresses vulnerability 4.

Firewall Maintenance, Disabling Unused Ports, and Port Filtering:
Rules on the firewall block suspicious traffic from outside the network and allow only what the organization needs. Regular reviews keep old or too-open rules from becoming a weak spot. The rules need to be reviewed monthly or quarterly, after any incident, and when the network changes.

Every open port is a possible way in. Closing the ones nobody uses leaves attackers fewer places to try. So be sure to check unused ports during regular network reviews, such as quarterly, and whenever a service is added or removed.

Port filtering allows traffic only on the ports that are needed and blocks the rest, which further reduces what attackers can reach. This can be reviewed together with the firewall rules.

All of this addresses vulnerability 3.

The following are additional tools and methods that I recommend to further strengthen the network's security, beyond the four major vulnerabilities mentioned:

SIEM Tools and IPS: These provide another layer of protection in case an attack gets past the firewall. They detect suspicious activity and help stop it early. They run all the time. Analysts should check alerts daily and adjust the detection rules every few months.

Encryption Using the Latest Standards: Using current encryption standards, such as a VPN, protects data as it travels across the network and prevents packet sniffing. Review the encryption standards at least once a year and upgrade when older ones are retired.

Server and Data Storage Backups: Regular backups allow the organization to recover its data after an attack. Backups should be done daily or weekly, depending on how fast the data changes. Test restoration every few months to make sure they work.

Patch Updates: Keeping software and operating systems up to date fixes known security weaknesses before attackers can use them. Apply updates on a regular schedule, such as monthly. Apply urgent security patches as soon as possible.